LearningMore - Chat Management

Owner:
Reviewer:
Contributors:
Date Generated: Sun Apr 19 2026

Executive Summary

High level system description

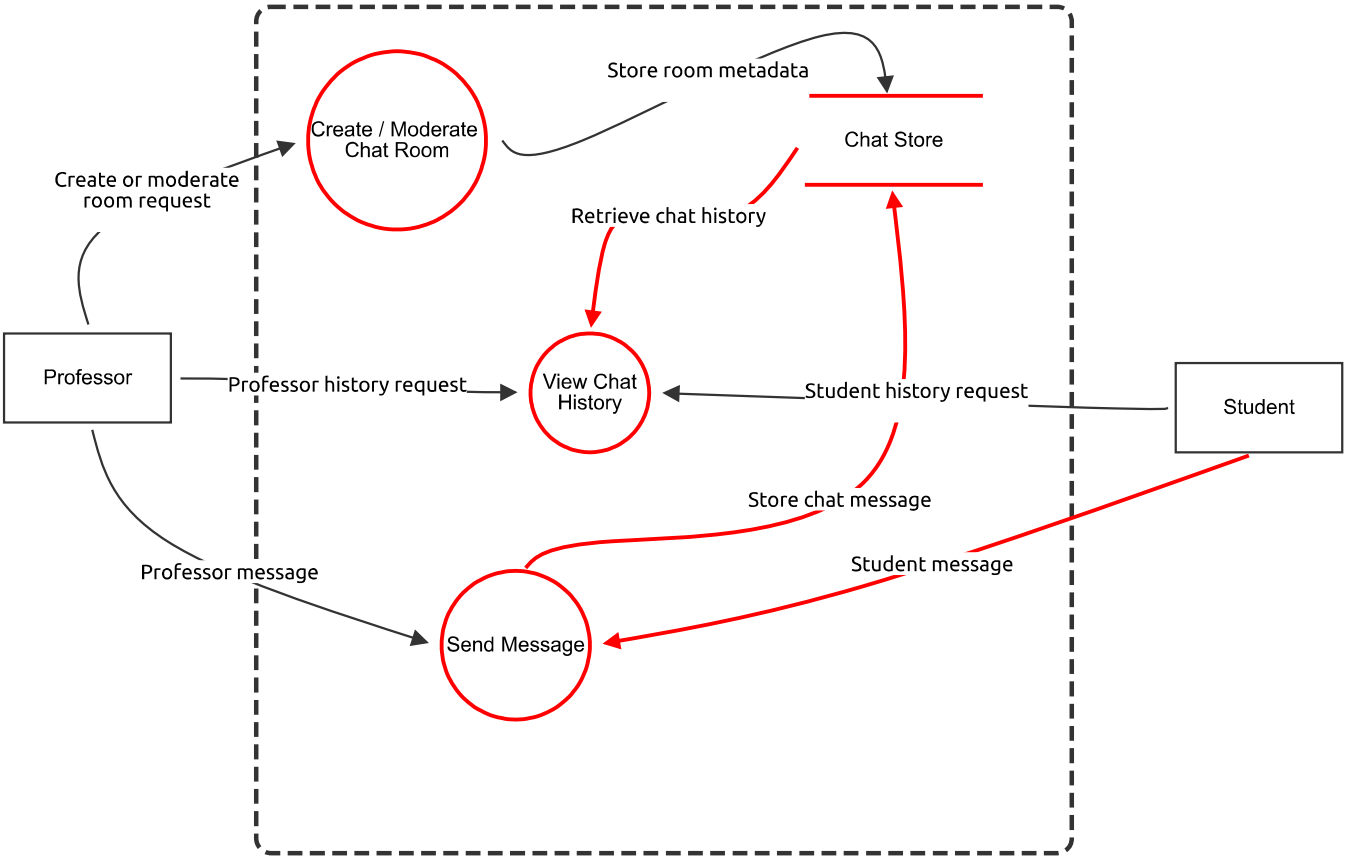
Threat model for the Chat Management component of the LearningMore platform, including chat room creation, message exchange, and history retrieval between students and professors.

Summary

Total Threats	9
Total Mitigated	0
Total Open	9
Open / Critical Severity	0
Open / High Severity	9
Open / Medium Severity	0
Open / Low Severity	0

Chat Management DFD Level 2

DFD for Chat Management including chat room creation, messaging, and history retrieval.



Chat Management DFD Level 2

Professor (Actor)

Description: Represents a professor interacting with the chat system.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Create / Moderate Chat Room (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	Unauthorized chat room management	Elevation of privilege	High	Open		A student may attempt to create or moderate chat rooms without having the required permissions.	Enforce role-based access control and verify user roles before allowing room creation or moderation.

Chat Store (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	Unauthorized access to chat history	Information disclosure	High	Open		An attacker may gain unauthorized access to stored chat messages, exposing sensitive communication between students and professors.	Enforce strict access control policies, restrict database access, and ensure proper authorization checks before retrieving chat data.
9	Modification of stored chat messages	Tampering	High	Open		An attacker may modify stored chat messages, compromising integrity of communication data.	Use database access controls, integrity checks, and audit logging to detect and prevent unauthorized modifications.

Professor message (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Create or moderate room request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Professor history request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Store chat message (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Message alteration before storage	Tampering	High	Open		An attacker may modify chat messages before they are stored, leading to incorrect or malicious content being persisted.	Validate and sanitize inputs on the server side and ensure secure communication channels.

Retrieve chat history (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	Interception of chat history data	Information disclosure	High	Open		An attacker may intercept chat history data during transmission, exposing sensitive information.	Use HTTPS/TLS encryption for all communications and enforce secure transport protocols.

Data Flow (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Student message (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	Message manipulation in transit	Tampering	High	Open		An attacker may intercept and modify chat messages while they are transmitted between the client and the server, altering message content or injecting malicious data.	Use HTTPS/TLS to encrypt all communications and validate message integrity on the server side.

Student history request (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Student (Actor)

Description: Represents a student interacting with the chat system.

Number	Title	Type	Severity	Status	Score	Description	Mitigations

View Chat History (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
7	Unauthorized access to chat history	Information disclosure	High	Open		An attacker may access chat history without proper authorization, exposing sensitive communication between users.	Enforce strict authorization checks and validate user permissions before returning chat history.

Send Message (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
2	User impersonation in chat messages	Spoofing	High	Open		An attacker may impersonate another user (student or professor) by forging authentication tokens or manipulating requests, allowing them to send messages on behalf of other users in the chat system.	Implement strong authentication using JWT with signature validation, enforce token expiration, and validate user identity and roles on every request at the server side.
6	Chat message flooding	Denial of service	High	Open		An attacker may send a high volume of messages to overwhelm the chat system, affecting availability and degrading user experience.	Implement rate limiting, request throttling, and message size limits to prevent abuse.